

CRISC Exam - Hard Concepts & Exam Traps

Section 2: IT Risk Assessment Deep Dive Tutorial

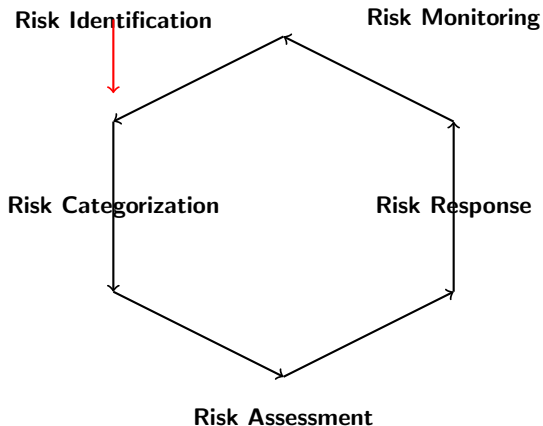
CRISC Mastery Series

July 19, 2026

Section 2 Tutorial Outline

1. Risk Management Life Cycle
 - 1.1 The 5-Step Life Cycle
 - 1.2 Issues, Events, Incidents, Breaches
2. Threat, Vulnerability, and Risk
 - 2.1 Core Concepts
 - 2.2 Threat Modeling
 - 2.3 Vulnerability Analysis
3. Risk Assessment Approaches
 - 3.1 Top-Down vs Bottom-Up
 - 3.2 Qualitative vs Quantitative
4. Risk Assessment Frameworks
 - 4.1 Industry Frameworks
 - 4.2 Risk Assessment Techniques
5. Business Impact Analysis (BIA)
 - 5.1 BIA vs Risk Assessment
 - 5.2 Recovery Objectives
6. Inherent, Residual, and Current Risk
 - 6.1 Understanding the Risk Types
7. Risk Register
 - 7.1 Understanding the Risk Register
8. Common Exam Traps
 - 8.1 Risk Assessment Traps
9. Quick Reference
 - 9.1 Assessment Formulas

1.1 The IT Risk Management Life Cycle



1.1 Detailed Life Cycle

Step 1: Risk Identification

- **First** step - "You can't protect what you don't know"
- Identify all **threats** and **vulnerabilities**
- Document in **risk register**
- **Iterative** process - risks emerge over time

Step 2: Risk Categorization

- Classify risks by **type** and **severity**
- Critical/High/Medium/Low
- Assign to appropriate stakeholders
- Enables **prioritization**

The Critical Trap

Risk identification is **NOT** a one-time event. New risks emerge throughout the project/organizational life cycle!

1.1 Steps 3-5

Step 3: Risk Assessment

- Evaluate based on **likelihood** and **impact**
- Determine **risk score** (Likelihood $\times$ Impact)
- Compare against **risk appetite** and **tolerance**
- Prioritize risks for treatment

Step 4: Risk Response

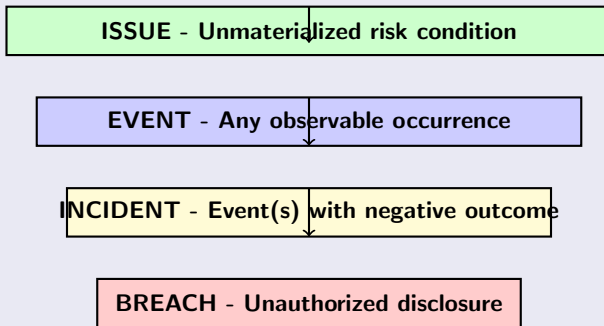
- Select treatment strategy: **Mitigate, Accept, Transfer, Avoid**
- Implement **controls**
- Document in **risk register**
- Obtain **management approval**

Step 5: Risk Monitoring

- **Continuous** monitoring of risks and controls
- Track **KRIs** and **KPIs**
- Identify **emerging risks**
- Review **control effectiveness**

1.2 Critical Terminology - The Hierarchy

Understanding the Progression



The Critical Trap

These terms are **NOT** interchangeable! Each represents a different level of severity and requires different responses.

1.2 Detailed Definitions

Issues

- Instance of IT risk that has **NOT materialized**
- Needs to be considered and kept on the **radar**
- Combination of control, value, and threat conditions
- **Example:** Outdated operating systems being used by employees

Events

- Any **observable** occurrence during a period of time
- Three types: Threat event, Loss event, Vulnerability event
- **Example:** A single failed login attempt

1.2 Incidents and Breaches

Incidents

- Event or **combination of events** with **negative outcome**
- Affects **CIA triad**
- Requires **immediate response**
- **Example:** Thousands of failed login attempts in one second

Breaches

- **Accidental** or **unlawful** destruction, loss, alteration
- Unauthorized **disclosure** or **access**
- **Regulatory** reporting required
- **Example:** Yahoo breach (2016), Equifax breach (2017)

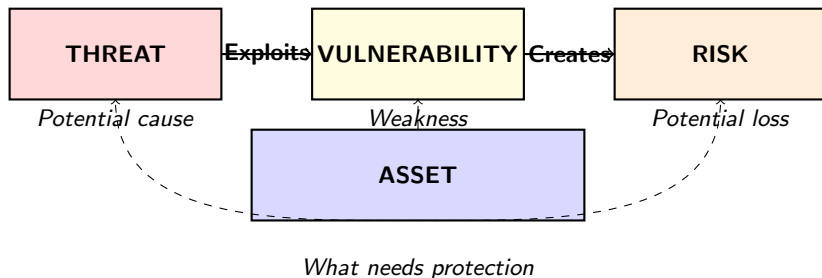
Key Distinction

Event = Any occurrence

Incident = Event(s) with *negative* outcome

Breach = Incident involving *unauthorized* access/disclosure

2.1 The Threat-Vulnerability-Risk Relationship



The Formula

$$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Asset Value}$$

2.1 Understanding Each Component

Threat

- Anything that could **impact** an asset
- Can be human, malicious code, natural disaster, etc.
- **Threat actor**: The entity that executes the threat
- **Threat vector**: The path used to gain access

Vulnerability

- **Weakness** in design, implementation, or operation
- Can be exploited by a threat
- Exists in hardware, software, configuration, or processes
- **Can be controlled** by implementing safeguards

Risk

- What happens when a threat exploits a vulnerability
- Potential **harm** to assets
- **Can be managed** but never eliminated

2.1 Example - Malware Attack

Scenario: Malware Infection

- **Threat:** Malicious actor who wrote the malware
- **Threat Actor:** Hacker sending phishing emails
- **Threat Vector:** Phishing email with malicious attachment
- **Vulnerability:** Missing antivirus; user opened infected file
- **Risk:** Laptops infected; data compromised
- **Asset:** Company data and systems

The Critical Insight

- **Threats** are **NOT** within our control
- **Vulnerabilities** **CAN** be controlled
- **Risk** is the **result** of threat exploiting vulnerability

What is Threat Modeling?

- **Structured approach** to identifying threats
- Identifies potential **vulnerabilities**
- Defines **security requirements**
- Quantifies threat criticality
- Prioritizes **remediation**

The 4-Step Cycle

- 1 **Model:** "What are we building?"
- 2 **Identify Threats:** "What could go wrong?"
- 3 **Mitigate:** "What countermeasures do we have?"
- 4 **Validate:** "Have we done all the steps?"

2.2 Threat Modeling Methods

STRIDE

Threat	Description	Security Principle
Spoofing	Impersonating another	Authenticity
Tampering	Modifying data	Integrity
Repudiation	Denying actions	Non-repudiation
Information Disclosure	Exposing data	Confidentiality
Denial of Service	Disrupting service	Availability
Elevation of Privilege	Gaining extra rights	Authorization

2.2 DREAD Model

DREAD Risk Assessment

Factor	Question
Damage	How bad is an attack?
Reproducibility	How easy is it to reproduce?
Exploitability	What effort is required?
Affected Users	How many people impacted?
Discoverability	How easy is it to find?

OCTAVE

- **Operationally Critical Threat, Asset, and Vulnerability Evaluation**
- Focuses on **organizational risks**
- Self-directed methodology
- Business and IT teams work together

2.3 Sources of Vulnerabilities

Key Vulnerability Sources

- **Vulnerability Assessment Scans** - Nessus, Qualys
- **Penetration Tests** - Annual or after major changes
- **Static Analysis** - Code pipeline issues
- **Dynamic Analysis** - Runtime scanning
- **Configuration Checks** - Misconfiguration issues
- **Risk Assessments** - Non-technical risks
- **Zero-Day Findings** - New vulnerabilities with no patch
- **Industry Advisories** - NIST, CISA, vendor bulletins

Key Insight

Identifying vulnerabilities is only half the battle. **Prioritizing and fixing** them is the other half!

2.3 Common Vulnerability Scoring System

CVSS - Quantifying Vulnerabilities

- **Industry standard** for scoring vulnerabilities
- Scores range from 0.0 to 10.0
- **Critical:** 9.0 - 10.0 - *Immediate action required*
- **High:** 7.0 - 8.9 - *Prioritize remediation*
- **Medium:** 4.0 - 6.9 - *Address in normal cycle*
- **Low:** 0.1 - 3.9 - *Consider for future*

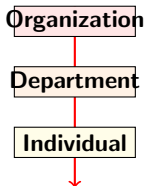
The Critical Trap

NOT all vulnerabilities are equal!

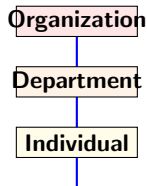
- Critical vulnerabilities must be remediated **IMMEDIATELY**
- Low vulnerabilities may be **accepted** or deferred
- Prioritization is **ESSENTIAL**

3.1 Top-Down vs Bottom-Up Assessment

Top-Down
Management Perspective



Bottom-Up
Team/Individual Perspective



Which is Better?

Use BOTH approaches together!

3.1 Top-Down Assessment

Characteristics

- **Driven by** management perspective
- Related directly to **business objectives**
- Easier to get **buy-in**
- Results tend to be **broad** in nature
- Based on management's **experience** across multiple functions

Example: Healthcare EHR System

- Board considers **strategic risks** with revenue implications
- E&C reviews **regulatory risks**
- Senior management evaluates **departmental risks**
- Cyber reports inform **system-specific risks**

3.1 Bottom-Up Assessment

Characteristics

- Identified by **individuals and teams**
- Cascaded up to department and organization level
- More **catered to specific business functions**
- Raised by **subject matter experts**
- Provides **detailed operational insights**

Example: Healthcare EHR System

- System-level components analyzed first
- Individual departments assess operational impact
- Senior management understands **KPI impacts**
- Organizational level considers **regulatory** and **reputational** risks

3.2 Qualitative Risk Analysis

Characteristics

- Based on **subjective** parameters
- Uses: High, Medium, Low, Very Low
- Assigns values based on **experience and expertise**
- **Less expensive**
- **Quick** to perform
- May be **biased** based on team expertise

Example

- Likelihood: High/Medium/Low
- Impact: High/Medium/Low
- Risk Score: Likelihood $\times$ Impact (e.g., High $\times$ High = Critical)

3.2 Quantitative Risk Analysis

Characteristics

- Based on **monetary values**
- Uses **historical data** for modeling
- Requires **reasonably accurate** data
- **More expensive**
- **Complex**; may need additional tools
- Results are **data-driven**

Key Formulas

- **SLE** = $AV \times EF$
 - SLE = Single Loss Expectancy
 - AV = Asset Value
 - EF = Exposure Factor (% loss)
- **ALE** = $SLE \times ARO$
 - ALE = Annualized Loss Expectancy
 - ARO = Annualized Rate of Occurrence

3.2 Quantitative Examples

SLE Calculation Example

- Asset Value = \$125,000
- Exposure Factor = 25% (0.25)
- $SLE = \$125,000 \times 0.25 = \mathbf{\$31,250}$

ALE Calculation Example

- $SLE = \$31,250$
- ARO = 4 (expected to happen 4 times per year)
- $ALE = \$31,250 \times 4 = \mathbf{\$125,000}$

The Critical Trap

- **Quantitative** is more complex and costlier
- **Qualitative** is subjective but faster
- **Choose based on business need**, not sophistication

3.2 Comparison Table

Qualitative vs Quantitative

Qualitative	Quantitative
Subjective	Objective
Risk severity is important	Monetary value is important
Requires experience and expertise	Requires historical data and modeling
Relatively straightforward	Complex
Results can be biased	Results are data-driven
Less expensive	More expensive

Semiquantitative (Hybrid)

- Combines **both** approaches
- Assigns numerical values to qualitative ratings
- Example: High = 5, Medium = 3, Low = 1
- Risk Score = Likelihood Score $\times$ Impact Score

4.1 Risk Assessment Frameworks

Common Frameworks

Framework	Description	Best For
NIST SP 800-30	Risk management for general IS	General organizations
NIST SP 800-37	Risk management for federal IS	Government agencies
NIST SP 800-161	Supply chain risk management	Supply chain
ISO/IEC 27005	Information security risk	IS risk management
ISO/IEC 31000	Organizational risk	Enterprise risk
FAIR	Quantitative risk taxonomy	Quantitative analysis
OCTAVE	Asset-based risk	Enterprise IT projects

4.1 Choosing the Right Framework

Considerations

- **Industry** requirements
- **Regulatory** compliance needs
- **Organizational** maturity
- **Available** resources
- **Budget** constraints
- **Culture** and risk appetite

Key Insight

- No single framework fits all organizations
- Choose what **makes sense** for your organization
- **Mix and match** frameworks if needed
- Ensure framework aligns with **business objectives**

4.2 Common Risk Assessment Techniques

Technique Overview

Technique	Type	Description
Bayesian Analysis	Quantitative	Uses prior data for probability
Bow Tie Analysis (BTA)	Diagram-based	Shows causes, controls, consequences
Brainstorming	Qualitative	Generates ideas with group
Delphi Method	Qualitative	Anonymous expert consensus
Event Tree Analysis	Quantitative	Forward-looking probabilities
Fault Tree Analysis	Quantitative	Top-down event analysis
Monte Carlo Analysis	Quantitative	Repeated random sampling
SWOT Analysis	Qualitative	Strengths, Weaknesses, Opportunities, Threats

4.2 Key Techniques Explained

Delphi Method

- Uses **expert opinion**
- **Multiple rounds** of questionnaires
- Anonymous responses
- Builds **consensus**
- Prevents **undue influence**

Fault Tree Analysis (FTA)

- Starts with an **event**
- **Top-down** analysis
- Examines possible means for event to occur
- Displays results in a **logical tree** diagram
- Identifies **root causes**

4.2 Monte Carlo and FAIR

Monte Carlo Analysis

- **Quantitative** technique
- Uses **repeated random sampling**
- Establishes **aggregate variation**
- Inputs have defined distributions
- Results show **probability ranges**

Factor Analysis of Information Risk (FAIR)

- **Quantitative** taxonomy
- Focuses on **data loss** events
- Establishes **accurate probabilities**
- Uses **frequency** and **magnitude**
- Industry standard for quantitative risk

5.1 BIA vs Risk Assessment

BIA (Business Impact Analysis)

- Identifies **critical business processes**
- Assesses **impact of disaster**
- Determines **recovery priorities**
- Output: RPO, RTO, MTD
- **Primary Goal:** Show how quickly to recover

Risk Assessment

- Identifies **threats** and **vulnerabilities**
- Evaluates **likelihood** and **impact**
- Recommends **controls**
- Output: Risk register, mitigation plans
- **Primary Goal:** Identify and manage threats

The Critical Trap

BIA and Risk Assessment are **NOT** the same!

BIA = "How quickly must we recover?"

Risk Assessment = "What threats do we face?"

5.2 Recovery Objectives

Three Key Metrics

Metric	Definition	Direction
RPO	Maximum acceptable data loss	Backward-looking
RTO	Maximum acceptable down-time	Forward-looking
MTD	Maximum tolerated outage	Total threshold

The Critical Trap

- **RPO** = "How much data can we lose?" - **BACKWARD**
- **RTO** = "How long can we be down?" - **FORWARD**
- **NEVER** confuse RPO and RTO directions!

5.2 Recovery Objectives Example

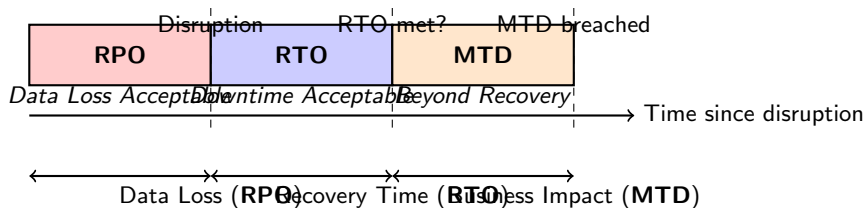
Scenario: Application Recovery

- RPO = 4 hours
 - Can accept losing up to 4 hours of data
 - Backups must run at least every 4 hours
- RTO = 8 hours
 - Application must be restored within 8 hours
 - Need plan for 8-hour recovery window
- MTD = 12 hours
 - Business cannot survive beyond 12 hours of downtime
 - **RTO < MTD** must ALWAYS be true!

Key Relationship

RTO must ALWAYS be less than MTD!

5.2 The Recovery Timeline



6.1 The Three Risk States

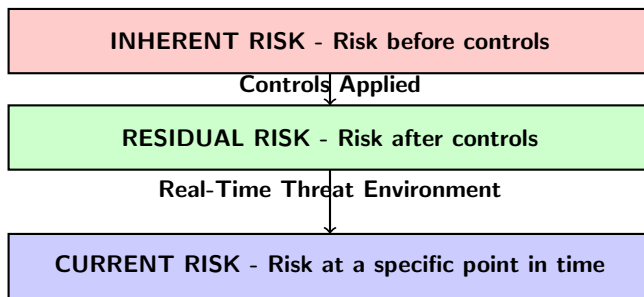
Risk Types Defined

Risk Type	Definition	When Measured
Inherent Risk	Risk without controls	Before any controls
Residual Risk	Risk after controls	After controls implemented
Current Risk	Risk in real-time	At specific point in time

The Critical Trap

- **Residual** = Theoretical risk after controls
- **Current** = Real-time risk in actual environment
- They are **NOT** interchangeable!

6.1 The Risk Reduction Equation



Key Formula

$$\text{Residual Risk} = \text{Inherent Risk} - \text{Controls}$$

6.1 Example - Laptop Security

Scenario: Laptop Without Antivirus

- **Inherent Risk:** Very high - laptop exposed to all viruses
- **Control:** Install antivirus software
- **Residual Risk:** Lower - protected against known viruses
- **Current Risk:** Varies daily - depends on new threats

Key Insights

- **Inherent risk** is ever-present
- **Controls reduce** risk but never eliminate it
- **Residual risk** is what remains after controls
- **Current risk** changes with the threat landscape

7.1 What is a Risk Register?

Definition

- **Main reference** for all risk-related information
- Documents **all identified risks**
- Tracks **risk status** and **response**
- Supports **risk-related decisions**

Key Components

- Risk **description**
- **Probability** of occurrence
- **Impact** if materialized
- **Risk Score** ($\text{Probability} \times \text{Impact}$)
- **Inherent risk** level
- **Current controls**
- **Residual risk** level
- **Mitigation actions**
- **Risk owner**
- **Status** (Open/Closed/Monitoring)

7.1 The Value of a Risk Register

The Critical Trap

Common Mistake: Thinking a risk register is just an inventory.

Correct: A risk register drives risk response decisions and establishes accountability!

Primary Value

- Drives the **risk response plan**
- Supports **prioritization** of responses
- Establishes **accountability**
- **Tracks** risk status over time
- Enables **reporting** and **dashboards**

7.1 Risk Register Maintenance

Best Practices

- Update **continuously**, not just annually
- Review **at least quarterly**
- Assign **clear ownership**
- Link to **business objectives**
- Include **actionable** information
- Use **centralized** system with workflow

The Critical Trap

- **Annual updates** = Risk register is **outdated**
- Risk environment changes **constantly**
- Update **when risks change**, not on a fixed schedule
- **Regular** evaluation is needed (e.g., quarterly)

8.1 Common Exam Traps - Risk Assessment

Trap #1: Qualitative vs Quantitative

- **Common Mistake:** Thinking quantitative is always better
- **Correct:** Choose based on business need
- **Quantitative:** More expensive, complex
- **Qualitative:** Less expensive, faster

Trap #2: Inherent vs Residual

- **Common Mistake:** Thinking controls eliminate all risk
- **Correct:** Residual risk always remains
- **Residual** = Inherent - Controls

8.1 More Common Traps

Trap #3: RPO vs RTO

- **Common Mistake:** Confusing the direction
- **Correct:** RPO is **backward-looking**; RTO is **forward-looking**
- **RPO** = Data loss tolerance
- **RTO** = Downtime tolerance

Trap #4: Event vs Incident

- **Common Mistake:** Using terms interchangeably
- **Correct:** Event is any occurrence; Incident has negative outcome
- **Event:** Failed login attempt
- **Incident:** 1000 failed login attempts in 1 second

Critical Formulas

- **SLE** = $AV \times EF$
 - SLE = Single Loss Expectancy
 - AV = Asset Value
 - EF = Exposure Factor
- **ALE** = $SLE \times ARO$
 - ALE = Annualized Loss Expectancy
 - ARO = Annualized Rate of Occurrence
- **Residual Risk** = Inherent Risk $\times$ Control Risk
- **Risk Score** = Likelihood $\times$ Impact

Memory Aid

- **SLE** = "Single loss from one event"
- **ALE** = "Annual loss from all events"
- **Residual** = "What's left after controls"

9.1 Risk Assessment Quick Reference

Key Definitions

Concept	Definition	Example
Threat	Potential cause of harm	Malicious actor
Vulnerability	Weakness	Missing antivirus
Inherent Risk	Risk without controls	New system without security
Residual Risk	Risk after controls	After firewall installed
Current Risk	Real-time risk	Today's threat level
RPO	Backward-looking	4 hours data loss
RTO	Forward-looking	8 hours recovery

IT Risk Assessment

Remember:

- Risk identification is **iterative**
- **Events** $\neq$ **Incidents** $\neq$ **Breaches**
- **Threats** are **not** controllable; **vulnerabilities** are
- Use **both** Top-Down and Bottom-Up approaches
- **Quantitative** = *Monetary*; **Qualitative** = *Subjective*
- **RPO** = *Backward*; **RTO** = *Forward*
- **Residual** = *Inherent - Controls*

Next: Section 3 - Risk Response and Reporting